Веб қосымшалардағы аутентификация сессияларды басқару және қол жеткізуді бақылау қауіпсіздігін талдау

СӨЖ 2 ЖОБАЛЫҚ ЖҰМЫС

AuthLab оқу веб қосымшасы

Пәні: Веб қауіпсіздігі

Тобы: СИБ 24-03

Орындағандар:

1. Азанбай Жалғас
2. Минайдар Алижан
3. Тулегенов Назирхан

Тексерген: Жұмабекова Айдана

Алматы, 2026 жыл

WEB SECURITY LAB

AUTH LAB

Веб-қосымшадағы аутентификация, сессиялар және қол жеткізуді бақылау

Қауіпсіздік механизмдерін жобалау және 17 тест сценарийі бойынша тексеру

Пәні: [пән атауы] Тобы: [топ]

Орындағандар: 1) [аты-жөні] 2) [аты-жөні] 3) [аты-жөні]



ЖОБАНЫҢ БАҒЫТЫ

Неге тек дұрыс пароль жеткіліксіз?

Кіруден кейінгі сессия немесе ресурсқа рұқсат дұрыс қорғалмаса, деректерге бөгде адам қол жеткізуі мүмкін.

01 **Аутентификация**

Пайдаланушының кім екенін тексеру

02 **Сессия қауіпсіздігі**

Кіру күйін сақтау және уақытында жою

03 **Авторизация**

Әр әрекет пен жазбаға рұқсатты тексеру

Зерттеу мақсаты

Осы механизмдерді кодта іске асырып, нақты HTTP жауаптары мен автоматтандырылған тестілер арқылы тексеру.

Қорғау бөлімі

1-СТУДЕНТ • LOGIN / PBKDF2

2-СТУДЕНТ • SESSION / CSRF

3-СТУДЕНТ • RBAC / IDOR

ЗЕРТТЕУ МАҚСАТЫ ЖӘНЕ ҚАУІПТЕР

Қандай тәуекелдерді қарастырдық?

Қауіп субъектісі ретінде аноним пайдаланушы немесе student рөліндегі аккаунт қарастырылды.

- **Бөгде кіру**
  Қате парольді болжау немесе login қорғанысын айналып өту
- **Сессияны пайдалану**
  Ескі не бекітілген токенді қайта қолдану
- **Рұқсатты бұзу**
  Өзгенің жазбасын немесе admin функциясын ашу
- **Сұранысты өзгерту**
  CSRF, XSS және SQL injection тәрізді енгізулер

Шектеу: Тесттер тек AuthLab оқу прототипіндегі маршруттар мен функцияларды қамтиды.

ЖҮЙЕ АРХИТЕКТУРАСЫ

AuthLab қалай жұмыс істейді?

Жергілікті браузер, Python HTTP өңдеушісі және SQLite дерекқоры бір ағынға біріктірілген.



Негізгі кестелер

users	логин, пароль хэші, рөл
sessions	сессия токені мен мерзімі
prelogins	кіру формасының уақытша токені
notes	жеке пайдаланушы жазбалары
login_failures	қате кіру әрекеттері

127.0.0.1 • LOCAL ONLY

АУТЕНТИФИКАЦИЯ ЖӘНЕ ПАРОЛЬ

Пароль қалай қорғалады?

Рөл веб-формада таңдалмайды; пайдаланушыны тек әкімші терминал арқылы тіркейді.

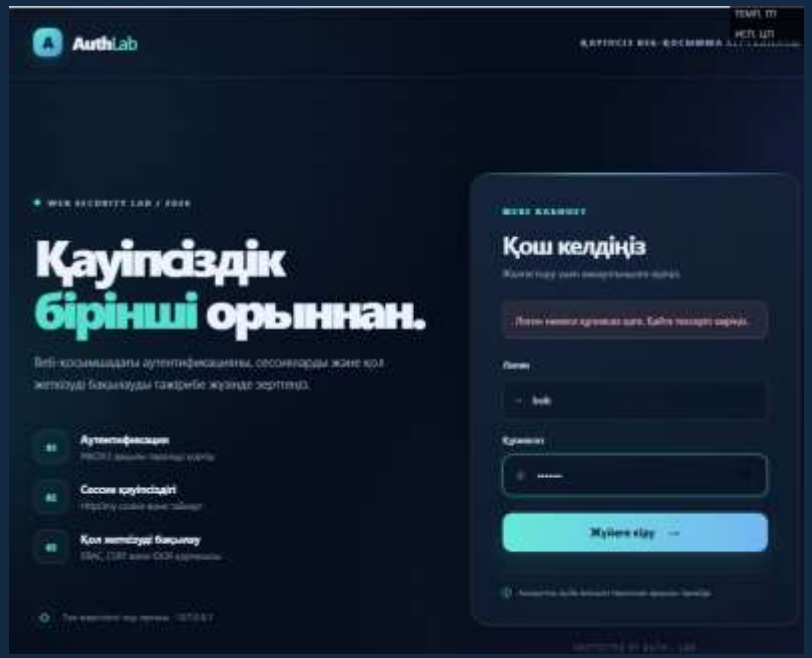
PASSWORD STORAGE

PBKDF2-HMAC-SHA-256

600 000 итерация

Әр пайдаланушыға жеке salt. Дерекқорда ашық пароль емес, хэш сақталады.

- Қате логин мен қате парольге ортақ хабарлама.
- 5 қате әрекеттен кейін 5 минуттық уақытша шектеу.



AuthLab login интерфейсі • браузер скриншоты

АУТЕНТИФИКАЦИЯНЫ ТЕКСЕРУ

Алғашқы 4 тест нені растады?

Тесттер anonymous access, пароль сақтау, қате пароль және login CSRF сценарийлерін қамтиды.

01	Анонимді кіру	/dashboard → 303 /login	Рұқсатсыз кіру тоқтатылды	PASS
02	Пароль сақтау	PBKDF2 хэші + salt	Ашық пароль сақталмайды	PASS
03	Қате пароль	401 + ортақ хабарлама	Аккаунт ақпараты ашылмайды	PASS
04	Login CSRF	CSRF жоқ → 403	Токенсіз кіру сұранысы қабылданбайды	PASS

Problems Output Terminal ···

```
[AuthLab] "GET /login HTTP/1.1" 200 -
[AuthLab] "GET /static/style.css HTTP/1.1" 200 -
[AuthLab] "GET /favicon.ico HTTP/1.1" 404 -
[AuthLab] "POST /login HTTP/1.1" 303 -
[AuthLab] "GET /dashboard HTTP/1.1" 200 -
[AuthLab] "GET /static/style.css HTTP/1.1" 200 -
[AuthLab] "POST /logout HTTP/1.1" 303 -
[AuthLab] "GET /login HTTP/1.1" 200 -
[AuthLab] "GET /static/style.css HTTP/1.1" 200 -
[AuthLab] "POST /login HTTP/1.1" 401 -
[AuthLab] "GET /static/style.css HTTP/1.1" 200 -
```

Сервер журналы: login, dashboard, logout және 401

Негізгі HTTP жауаптары

303 → redirect 401 → unauthorized 403 → forbidden

СЕССИЯНЫҢ ӨМІРЛІК ЦИКЛІ

Login → Session → Logout

HTTP сұраныстары тәуелсіз болғандықтан, сервер пайдаланушыны сессия cookie арқылы таниды.

01

GET /login

10 минуттық pre-login cookie және CSRF токені

02

POST /login

Пароль тексеріледі, жаңа 256-бит токен жасалады

03

GET /dashboard

Cookie хэші БД-мен салыстырылады; уақыт тексеріледі

04

POST /logout

CSRF тексеріліп, серверлік сессия жойылады

256 бит кездейсоқ токен

SHA-256 серверде токен хэші ғана сақталады

20 мин / 4 сағ

COOKIE ЖӘНЕ CSRF ҚОРҒАНЫСЫ

Сессия токенін қалай қорғаймыз?

Бір ғана cookie атрибуты жеткіліксіз: бірнеше механизм бірге қолданылады.

HttpOnly

JavaScript арқылы cookie оқуды шектейді

SameSite=Lax

Кросс-сайт сұраныстарда cookie жіберілуін шектейді

Secure

Cookie тек HTTPS байланысында жіберіледі

__Host-

HTTPS режимінде cookie атауына қосымша шектеу

SameSite — қосымша қабат, CSRF токенін алмастырмайды.

CSRF FLOW

1. Өзгеріс енгізетін POST сұранысы

2. Сервер CSRF токенін тексереді

3. Токен жоқ → 403 Forbidden

СЕССИЯ МЕН CSRF ТЕСТІЛЕРІ

05–06 және 09–12 сценарийлері

Тестілер cookie атрибуттарын, токенді жаңартуды, CSRF тексерісін және сессия мерзімін растайды.

05 Cookie flags — HttpOnly + SameSite — PASS

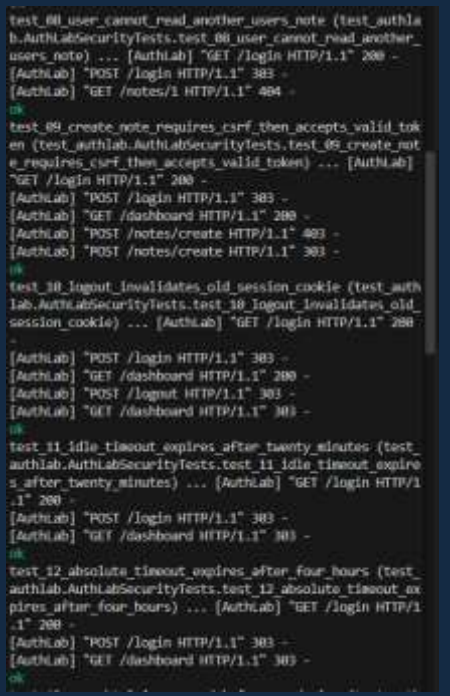
06 Session fixation — Ескі токен қабылданбайды — PASS

09 CSRF note create — Токенсіз 403; дұрыс токенмен 303 — PASS

10 Logout / replay — Ескі cookie жарамсыз — PASS

11 Idle timeout — 20 минуттан соң жарамсыз — PASS

12 Absolute timeout — 4 сағаттан соң жарамсыз — PASS



Тест 08–12 журналынан үзінді

RBAC — РӨЛ БОЙЫНША ҚОЛ ЖЕТКІЗУ

Кім қандай әрекет орындай алады?

Рөл тек сервер жағында тексеріледі; интерфейстегі батырманы жасыру жеткіліксіз.

Әрекет	Аноним	Студент	Оқытушы
Кіру формасы	Иә	Иә	Иә
Жеке кабинет	Жоқ	Иә	Иә
Өз жазбасын оқу / құру	Жоқ	Иә	Иә
Өзгенің жазбасын оқу	Жоқ	Жоқ	Жоқ
Пайдаланушылар тізімі	Жоқ	Жоқ	Иә

DENY BY DEFAULT

IDOR — ОБЪЕКТ ДЕҢГЕЙІНДЕГІ РҰҚСАТ

Өзгенің жазбасын ашуға бола ма?

Жүйе тек жазба ID-ін емес, оның иесін де тексереді.

Сұраныстағы тексеріс

```
SELECT * FROM notes
WHERE id = ? AND owner_id = ?
```

id + owner_id = user_id

TEST 08

GET /notes/1

Басқа пайдаланушының жазбасы

404 Ресурс жоқ немесе пайдаланушыға қолжетімсіз

Нәтиже: Бөтен жазба мазмұны ашылмайды; 404 жауабы ресурс туралы артық ақпаратты азайтады.

ЕНГІЗУ ДЕРЕКТЕРІ МЕН СҰРАНЫСТЫ ҚОРҒАУ

XSS, Brute Force және SQL Injection

Жүйе пайдаланушы енгізген мәтін мен авторизация сұраныстарын сервер жағында тексереді.

TEST 13

XSS

HTML escape + CSP

Қауіпті HTML мәтін ретінде көрсетіледі

PASS

TEST 14

Brute Force

5 қате → 5 минут шектеу

Қайталанатын пароль болжау тежеледі

PASS

TEST 15

SQL Injection

Параметрленген SQL

Енгізу SQL командасы ретінде орындалмайды

PASS

Тестілеу нәтижесі 13 → Escaped HTML 14 → 5 минуттық шектеу 15 → 401 Unauthorized

HTTP SECURITY HEADERS ЖӘНЕ HTTPS COOKIE

Сервер жауабында қандай қорғаныс бар?

№16 және №17 тестілер жауап тақырыптамалары мен HTTPS cookie режимінің конфигурациясын тексереді.

Content-Security-Policy	Рұқсат етілетін контент көздерін шектейді
Cache-Control: no-store	Жауапты браузер кэшінде сақтамауға бағыттайды
X-Content-Type-Options: nosniff	MIME түрін өздігінен анықтауды шектейді

Ескерту: Secure cookie тесті нақты TLS қосылымын іске қоспайды; конфигурацияны тексереді.

TEST 17

Secure

__Host- cookie prefix

HTTPS режиміне арналған cookie конфигурациясы.

PASS • CONFIG TEST

ЖАЛПЫ ТЕСТ НӘТИЖЕСІ

17 / 17 • PASS

Пайдаланушы жіберген терминал скриншоттарында тестілердің барлығы `ok`, соңында `Ran 17 tests` және `OK` көрсетілген.

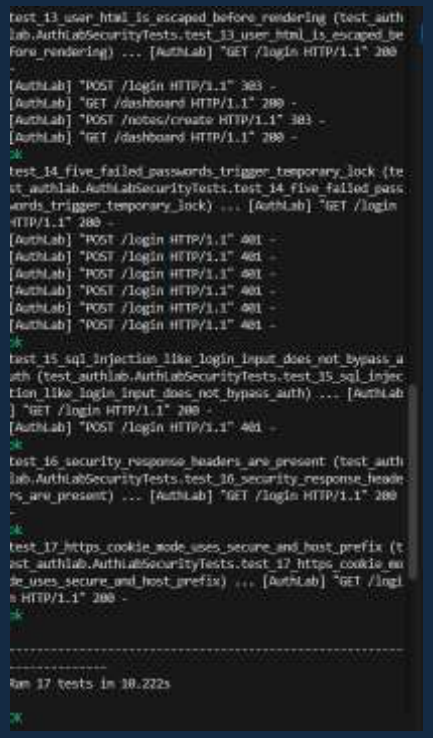
17/17

СӘТТІ ТЕСТ

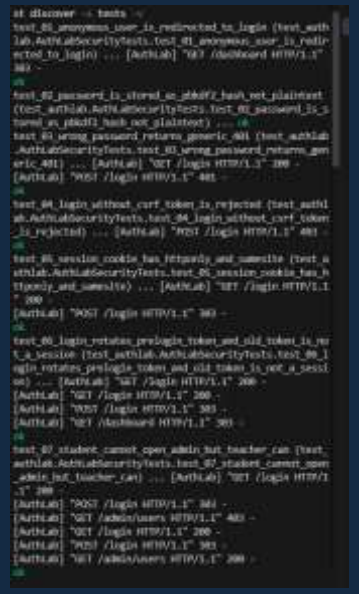
0 қате тіркелді

10.222 сек.

Тест жиынтығының орындалу уақыты



Тест 13–17 және қорытынды `OK`



Тест 01–07



Тест 08–12

ҚОРЫТЫНДЫ ЖӘНЕ КЕЛЕСІ ҚАДАМДАР

AuthLab нені дәлелдеді?

Қауіпсіздік бір ғана парольден тұрмайды: аутентификация, сессия және рұқсат тексерісі бірге жұмыс істеуі керек.

Оқу зертханасы	Қосымша тек 127.0.0.1 адресінде жұмыс істейді
Өндірістік сервер емес	Python http.server интернетке арналған production серверін алмастырмайды
Қамтылмаған бағыттар	MFA, қалпына келтіру, толық аудит, мониторинг, backup

ҚОРЫТЫНДЫ: 17/17 TEST PASS

Жетілдіру жоспары

- HTTPS және сенімді TLS прокси
- Көп факторлы аутентификация (MFA)
- Rate limiting, аудит және мониторинг
- Қауіпсіз резервтік көшіру
- Қосымша тест және сыртқы аудит

ДЕРЕККӨЗДЕР

Негізгі нұсқаулықтар және сұрақтар

Жобаның теориялық және практикалық бөлімдері төмендегі материалдарға сүйенеді.

01 OWASP Authentication Cheat Sheet

02 OWASP Password Storage Cheat Sheet

03 OWASP Session Management Cheat Sheet

04 OWASP Authorization Cheat Sheet

05 OWASP Cross-Site Request Forgery Prevention Cheat Sheet

06 OWASP Web Security Testing Guide

07 Python: hashlib және sqlite3 құжаттамасы

Сұрақтарыңыз бар ма?

НАЗАРЛАРЫҢЫЗҒА РАҚМЕТ!